

Cyber-11: Sécurisation http

Sécurisation des services réseaux :

Étude et mise en place d'un système de chiffrement pour le protocole HTTP

Config en ssh : ssh administrateur@192.31.25.19

Nous allons utiliser une architecture composée d'un **serveur** (ubuntu server) et un **client**.
Les deux sur un réseau **interne** derrière une **RT-Box**.

Installation et configuration d'un serveur web (déjà faite en R2.03)

1. Choisissez un serveur web, comme **Apache** ou Nginx. Pour cet exemple, nous utiliserons Apache.
2. Installez le serveur web sur votre système d'exploitation (Linux, Windows ou macOS). Par exemple, sous Linux, vous pouvez utiliser la commande suivante pour installer Apache :

sudo apt-get install apache2

3. Configurez le serveur web en modifiant les fichiers de configuration appropriés. Pour Apache, le fichier de configuration principal est généralement situé dans **/etc/apache2/apache2.conf** (sous Linux).

Dans nano **/etc/apache2/sites-available/000-default.conf**

```
# vim: syntax=apache ts=4 sw=4 sts=4 sr noet
<VirtualHost *:80>
    ServerAdmin admin@votredomaine.com
    DocumentRoot /var/www/html

    <Directory /var/www/html>
        AllowOverride None
        Require all granted
    </Directory>

    ErrorLog ${APACHE_LOG_DIR}/error.log
    CustomLog ${APACHE_LOG_DIR}/access.log combined
</VirtualHost>
```

4. Créez un fichier HTML simple (par exemple, **index.html**) et placez-le dans le répertoire racine du serveur web (par exemple, **/var/www/html** sous Linux pour Apache).

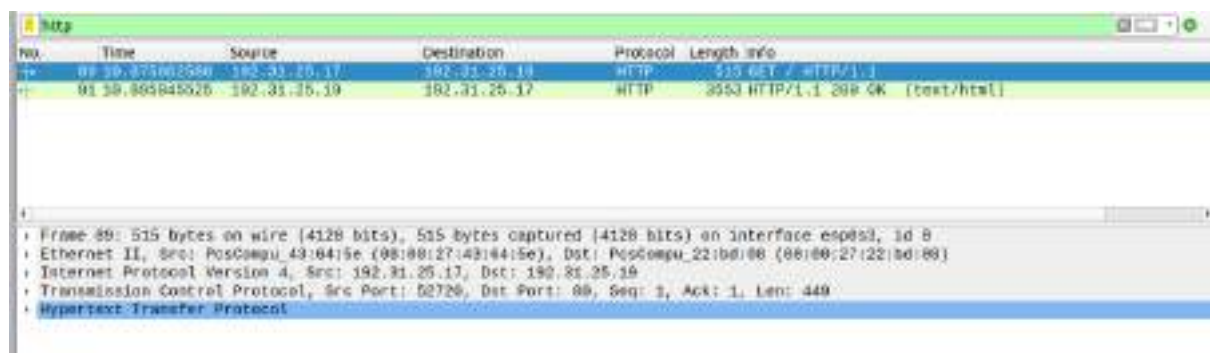
ciszak Lisa
Varnier Alexis



5. Redémarrez le serveur web pour appliquer les modifications. Sous Linux, utilisez la commande suivante pour redémarrer Apache :

`sudo systemctl restart apache2`

6. Testez votre installation en accédant à l'adresse **http://localhost** ou **http://<adresse IP de votre serveur>** depuis un navigateur web. Vous devriez voir le contenu de votre fichier **index.html**.
7. Analyser les trames avec Wireshark, sur le client.



Configuration du serveur web pour utiliser SSL/TLS

1. **Installez le module SSL** pour votre serveur web. Pour Apache sous Linux, utilisez la commande suivante :

`sudo apt-get install apache2-mod-ssl`

2. **Activez le module SSL**. Pour Apache sous Linux, utilisez la commande suivante :
`sudo a2enmod ssl`

`systemctl restart apache2`

```
Module ssl already enabled
root@rt-mv-srv:/home/administrateur# sudo a2enmod ssl
```

ciszak Lisa
Varnier Alexis

3. **Générez un certificat SSL auto-signé.** Vous pouvez utiliser OpenSSL avec la commande suivante :

`openssl req -x509 -newkey rsa:4096 -keyout key.pem -out cert.pem -days 365`

```
root@ip-10-10-10-10:~# openssl req -x509 -newkey rsa:4096 -keyout key.pem -out cert.pem -days 365
Generating a RSA private key
.....
writing new private key to 'key.pem'
-----
You are about to be asked to enter information that will be incorporated
into your certificate request.
What you are about to enter is what is called a Distinguished Name or a DN.
There are quite a few fields but you can leave some blank.
For some fields there will be a default value,
If you enter '.', the field will be left blank.
-----
Country Name (2 letter code) [AU]:fr
State or Province Name (full name) [Some-State]:Ile-de-France
Locality Name (eg, city) []:Paris
Organization Name (eg, company) [Internet Widgits Pty Ltd]:Bouy
Organizational Unit Name (eg, section) []:IT
Common Name (e.g. server FQDN or YOUR name) []:www.bouy.com
Email Address []:lisa@bouy.com
root@ip-10-10-10-10:~#
```

Quelle est la différence entre ce certificat et un obtenu auprès d'une autorité de certification (CA) comme Let's Encrypt ?

Un certificat auto-signé est créé localement et non reconnu par défaut par les navigateurs, nécessitant une validation manuelle. En revanche, un certificat délivré par Let's Encrypt est signé par une CA reconnue, assurant une connexion sécurisée sans alertes. Le premier convient aux tests et usages internes, tandis que le second est recommandé pour les sites publics.

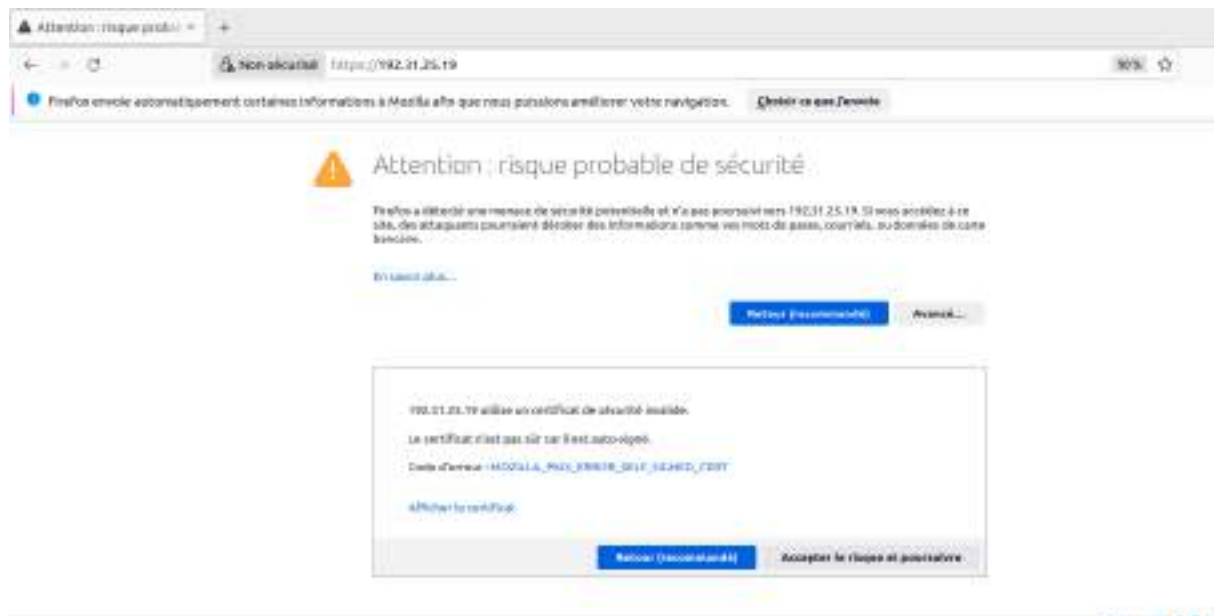
4. Copiez les fichiers **key.pem** (clé privée) et **cert.pem** (certificat) dans un répertoire sécurisé, par exemple **/etc/apache2/ssl/**.
5. Configurez votre serveur web pour utiliser le certificat SSL. Pour Apache, modifiez le fichier de configuration SSL (par exemple, **/etc/apache2/sites-available/default-ssl.conf** sous Linux) pour pointer vers les fichiers **key.pem** et **cert.pem**.
6. Activez le site SSL et redémarrez le serveur web. Pour Apache sous Linux, utilisez les commandes suivantes :

`sudo a2ensite default-ssl`

`sudo systemctl restart apache2`

Tests de la solution mise en place

1. Accédez à votre site web en utilisant l'adresse **https://localhost** ou **https://<adresse IP de votre serveur>** depuis un navigateur web. Vous devriez voir un avertissement de sécurité si vous utilisez un certificat auto-signé. Acceptez l'avertissement pour continuer.



2. Vérifiez que la connexion est sécurisée en examinant les informations sur le certificat et la connexion SSL/TLS dans votre navigateur web. Vous devriez voir un cadenas (généralement vert) à côté de l'URL de votre site dans la barre d'adresse. En cliquant sur ce cadenas, vous pourrez accéder aux détails du certificat SSL, tels que l'autorité de certification, la date d'expiration et les algorithmes de chiffrement utilisés.

Informations sur la clé publique	
Algorithme	RSA
Taille de la clé	2048
Exposant	65537
Module	AD:DE:12:75:A1:38:86:45:D6:DC:A5:B3:15:19:22:E2:14:AC:9D:95:B8:74:5F:0A: B1:8E:63:93:15:68:10:59:6C:EC:30:EA:89:A4:F6:5B:62:1D:79:C5:83:50:8F:0D:E 4:C3:AC:F8:35:5B:1A:35:67:5F:1F:0C:E6:32:F3:36:A1:C6:3A:33:4E:7F:88:D0:68:F 3:77:E1:CB:C6:75:36:56:48:BE:F5:EC:1E:B4:D0:56:C5:D5:58:F7:69:77:07:2C:57: 82:49:F6:BF:BE:01:57:4F:C4:73:49:3A:B8:36:AC:34:FD:56:BD:74:F1:BB:F4:4A:E 2:9F:43:19:81:54:D9:B2:CB:C0:AD:0A:21:94:5D:D2:50:C8:FC:B7:65:B7:3C:4E:9 B:C9:43:8D:84:36:77:5E:C9:9C:CD:3A:21:7E:48:B3:A5:F3:68:1F:3D:42:D5:3D:9 4:77:BC:E3:C0:DA:19:7E:B3:7B:A2:41:AC:EC:48:13:F5:97:D6:59:1A:40:5E:25:97: BC:3B:43:DB:12:70:10:85:3B:52:90:08:A2:6A:B8:DB:7F:9D:B7:F0:EB:6B:FA:ED: E3:2E:F4:4A:46:A9:2A:A1:92:0A:E5:33:6F:47:BE:CC:43:F9:11:D7:5F:A4:C4:52:A 5:A1:30:39:B4:F5:2D:3D:1B:C6:8A:6D:6F
Divers	
Numéro de série	79:7E:37:C7:B7:C5:E4:F3:2D:6B:5F:79:FB:B9:96:B7:1A:F3:5F:0A
Algorithme de signature	SHA-256 with RSA Encryption
Version	3
Télécharger	PEM (cert) PEM (chain)

ciszak Lisa
Varnier Alexis

3. Analyser maintenant les trames avec wireshark



Redirection HTTP vers HTTPS

Pour forcer la redirection des visites en **HTTP** vers **HTTPS**, vous pouvez suivre les instructions de la documentation officielle de votre serveur web. Voici les liens vers la documentation pour Apache et Nginx :

- **Apache** : [**https://httpd.apache.org/docs/2.4/mod/mod_rewrite.html**](https://httpd.apache.org/docs/2.4/mod/mod_rewrite.html)
- **Nginx** : [**https://nginx.org/en/docs/http/configuring_https_servers.html#redirect**](https://nginx.org/en/docs/http/configuring_https_servers.html#redirect)

Consultez la documentation appropriée pour obtenir des informations détaillées sur la mise en place de la redirection HTTP vers HTTPS pour votre serveur web spécifique.

```
# vim: syntax=apache ts=4 sw=4 sts=4 sr noet
<VirtualHost *:80>
    ServerAdmin admin@votredomaine.com
    DocumentRoot /var/www/html
    ServerName 192.31.25.19
    Redirect permanent / https://192.31.25.19/
    <Directory /var/www/html>
        AllowOverride None
        Require all granted
    </Directory>
```

ServerName 192.31.25.19

Redirect permanent / https://192.31.25.19/

Les entêtes de sécurité

Comment configurer les en-têtes de sécurité pour améliorer la sécurité du site web et se protéger contre les vulnérabilités courantes telles que le détournement de clic, les attaques XSS et le détournement de contenu ?

Dans le cadre de ce TP, vous devrez implémenter et expliquer l'utilisation des en-têtes de sécurité suivants :

- **Strict-Transport-Security (HSTS)** : Assure que le navigateur se connecte toujours au serveur en utilisant HTTPS.
- **X-Content-Type-Options** : Empêche les attaques de détournement de contenu en désactivant l'interprétation MIME sniffing.
- **X-XSS-Protection** : Active la protection XSS intégrée au navigateur.
- **X-Frame-Options** : Protège contre les attaques de détournement de clic en contrôlant l'affichage de votre contenu dans les iframes.
- **Referrer-Policy** : Contrôle la manière dont les informations de référence sont envoyées lors de la navigation entre les sites.

Ajoutez ces en-têtes de sécurité à la configuration de votre serveur web et expliquez leur importance pour améliorer la sécurité de votre site